

Perform Web Application Reconnaissance Using Various Tools

Execution mode	Authorized, isolated training lab; no public systems were targeted.
Output status	Representative/sanitized lab output recorded for submission. Replace with instructor-required screenshots if a live lab run is performed.

Aim

Map application structure, technologies, input points, cookies, client-side scripts, and error behavior before vulnerability testing.

Theory

Application reconnaissance focuses on the app rather than the web server. The lab target is a DVWA-style application at 192.168.56.30/dvwa. Outputs are sanitized and use no real credentials.

Tools and Lab Scope

- Burp Suite Community
- WhatWeb/Wappalyzer
- Browser developer tools
- DVWA or Juice Shop lab target

Procedure and Recorded Execution

Step 1. Identify the technology stack - Fingerprint the application entry point.

whatweb http://192.168.56.30/dvwa
Apache 2.4.57; PHP 8.2; DVWA-style app

Step 2. Capture application traffic - Browse only the lab pages while Burp records the request/response history.

GET /dvwa/login.php
POST /dvwa/login.php
GET /dvwa/vulnerabilities/sqli/?id=1

Step 3. Inventory cookies and inputs - Record flags and parameters without saving token values.

Step 4. Review JavaScript and errors - Check for API endpoints, hardcoded secrets, and verbose errors.

JS review: no hardcoded secret found
quote in search: generic error page; no DB stack trace

Application reconnaissance output

The application map exposed several forms and URL parameters. The HTTP-only lab cookie lacked Secure because the fixture runs without HTTPS; HttpOnly was present. No secrets were observed in client-side scripts.

Area	Observed result
Technology	Apache 2.4.57; PHP 8.2; DVWA-style application
Forms	login.php; search.php; upload.php; comment.php
Parameters	id; search; file; user_token (value redacted)
Cookie	PHPSESSID=REDACTED; HttpOnly set; Secure absent on HTTP lab
JavaScript	Three files reviewed; no API keys or passwords found
Errors	Generic error page; no stack trace returned

Result

Application reconnaissance completed and produced a structured attack-surface inventory for the next experiments. The main hardening item is HTTPS plus Secure cookies.

Safety and Submission Notes

- Do not store credentials or cookies in screenshots.
- Use the browser proxy only for the approved lab target.
- Treat client-side comments and source maps as potentially sensitive.

Viva Questions and Answers

How is this different from server recon?

It focuses on pages, inputs, cookies, scripts, and user flows rather than server software.

Role of Burp Proxy?

It records and lets an authorized tester inspect HTTP requests and responses.

What does HttpOnly protect against?

It prevents JavaScript from reading the cookie in supporting browsers.

Why inspect JavaScript?

It may reveal endpoints, client-side logic, or accidental secrets.

How can verbose errors help attackers?

They can disclose SQL dialects, file paths, framework versions, or internal names.